VULNERABILITY ASSESSMENT & PENETRATION TESTING (VAPT) REPORT

Prepared By: DIVAKAR Bagathi

Date: 02 March 2026

Tools Used: OpenVAS, Nmap, Manual Testing Techniques

Confidentiality: This document contains sensitive security information and is intended only for authorized stakeholders.

1. Executive Summary

A comprehensive Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted using OpenVAS, Nmap, Burp Suite, and manual validation techniques. A total of 56 vulnerabilities were identified across network services and web applications. Critical

findings include insecure remote services and weak authentication mechanisms that may allow unauthorized access and system compromise.

2. Scope of Assessment

• Target IP(s): 192.168.230.131

• Testing Type: Blackbox

• Assessment Period: 20-feb-2026 - 06-march-2026

3. Methodology

Phase 1 – Reconnaissance (Nmap scanning and service enumeration)

Phase 2 – Vulnerability Scanning (OpenVAS automated scanning)

Phase 4 – Manual Validation and Exploit Confirmation

4. Vulnerability Summary

Total Vulnerabilities Identified: 56

Critical: 8

High: 10

5. Detailed Vulnerability Findings

V-01: Insecure rexec Service with Weak Credentials

Severity: Critical (CVSS 10.0)

Port: 512/tcp

Service: netkit-rsh rexecd

Description

The target system exposes the legacy **rexec (Remote Execution Protocol)** service on TCP port 512.
The service allows remote authentication and command execution over an unencrypted channel.

Nmap script rexec-brute confirmed multiple valid credentials including default username/password combinations.

Proof of concept(Poc)

nmap -p 512 -sV --script rexec-brute 192.168.230.131

Output confirmed:

- root:root – Valid credentials
- netadmin:netadmin – Valid credentials

```
┌──(root㉿kali)-[/home/divakar]
└─# nmap -p 512 --script rexec-brute 192.168.230.131
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-02 16:51 IST
Nmap scan report for 192.168.230.131
Host is up (0.00066s latency).

PORT    STATE SERVICE
512/tcp open  exec
| rexec-brute:
|   Accounts:
|     root:root - Valid credentials
|     netadmin:netadmin - Valid credentials
|     user:user - Valid credentials
|     test:test - Valid credentials
|     web:web - Valid credentials
|     webadmin:webadmin - Valid credentials
|     administrator:administrator - Valid credentials
|     sysadmin:sysadmin - Valid credentials
|     admin:admin - Valid credentials
|     guest:guest - Valid credentials
|_  Statistics: Performed 15 guesses in 1 seconds, average tps: 15.0
MAC Address: 00:0C:29:AD:2E:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.80 seconds

┌──(root㉿kali)-[/home/divakar]
└─#
```

Impact

An attacker can:

- Gain unauthorized remote access
- Execute arbitrary commands
- Obtain root-level control
- Intercept credentials in cleartext
- Fully compromise the system

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Disable rexec service
- Remove rsh packages
- Block port 512
- Replace with SSH
- Enforce strong authentication policies

V-02: Distributed Ruby (DRb) Remote Code Execution Risk

Severity: Critical (CVSS 10.0)

Port: 8787/tcp

Service: Ruby DRb RMI (Ruby 1.8)

Description

The system exposes a Distributed Ruby (DRb) service on TCP port 8787 running **Ruby 1.8**, which is End-of-Life.

DRb allows remote method invocation over a network. When exposed without authentication and running outdated Ruby versions, it may allow remote attackers to execute arbitrary Ruby code.

Proof of concept(Poc)

nmap -p 8787 -sV 192.168.230.131

Output:

8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)

Manual validation:

nc -nv 192.168.230.131 8787

```
┌──(root㉿kali)-[/home/divakar]
└─# nmap -p 8787 -sV 192.168.230.131
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-02 17:22 IST
Nmap scan report for 192.168.230.131
Host is up (0.00084s latency).

PORT     STATE SERVICE VERSION
8787/tcp open  drb     Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
MAC Address: 00:0C:29:AD:2E:80 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.47 seconds
```

Connection successful → Service reachable externally.

Impact

An attacker may:

- Execute arbitrary Ruby code
- Gain shell access
- Escalate privileges
- Compromise application logic
- Perform lateral movement

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Disable DRb service if not required
- Restrict service to localhost
- Block port 8787 via firewall
- Upgrade Ruby to supported version
- Implement authentication controls

V- 3: Operating System End-of-Life Detection

Severity: High (CVSS 10.0)

Description

The target system is running an Operating System version that has reached End-of-Life (EOL) status.

EOL systems:

- No longer receive security patches
- Contain publicly known vulnerabilities
- Are unsupported by vendor

Proof of Concept(PoC)

Detected via OpenVAS OS fingerprinting and service identification.

Example validation:

nmap -O 192.168.230.131

```
┌──(root㉿kali)-[/home/divakar]
└─# nmap -O 192.168.230.131
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-02 17:17 IST
Nmap scan report for 192.168.230.131
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 00:0C:29:AD:2E:80 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.00 seconds
```

OS version corresponds to unsupported release.

Impact

Running an unsupported OS increases risk of:

- Remote Code Execution
- Privilege Escalation
- Data Breach
- Ransomware Infection
- Complete System Compromise

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Upgrade to a supported OS version
- Apply latest security patches
- Implement patch management policy
- Monitor vendor lifecycle announcements

V-04: Possible Backdoor – Ingreslock

Severity: Critical (CVSS 10.0)

Port: 1524/tcp

Service: ingreslock

Description

The target system exposes a service on TCP port 1524 identified as **Ingreslock**, a known backdoor service.

Ingreslock provides unauthenticated remote shell access and allows execution of arbitrary system commands. The presence of this service indicates either intentional insecure configuration (lab environment) or potential system compromise.

Backdoor services significantly increase the risk of full system takeover.

Proof of Concept (PoC)

Service detection:

1524/tcp open ingreslock

Command used:

nmap -p 1524 -sV 192.168.230.131

Manual validation:

nc -nv 192.168.230.131 1524

```
└─# nc 192.168.230.131 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:ad:2e:80
          inet addr:192.168.230.131  Bcast:192.168.230.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fead:2e80/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1987 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1399 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:134983 (131.8 KB)  TX bytes:93707 (91.5 KB)
          Base address:0x2000 Memory:fd5c0000-fd5e0000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:407 errors:0 dropped:0 overruns:0 frame:0
          TX packets:407 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:156933 (153.2 KB)  TX bytes:156933 (153.2 KB)

root@metasploitable:/#
```

Connection established successfully, confirming the service is accessible remotely.

Impact

An attacker can:

- Gain immediate remote shell access
- Execute arbitrary system commands
- Escalate privileges
- Install malware or maintain persistence
- Fully compromise the target system

This represents complete loss of confidentiality, integrity, and availability.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Immediately disable the service running on port 1524
- Remove unauthorized backdoor binaries
- Conduct a full system integrity assessment
- Restrict unnecessary open ports via firewall
- Rebuild the system if compromise is suspected

V-05: DistCC Remote Code Execution Vulnerability

Severity: High (CVSS 9.3)

OID: 1.3.6.1.4.1.25623.1.0.103553

Port: 3632/tcp

Service: distccd

Description

The DistCC service is exposed on TCP port 3632 and is vulnerable to unauthenticated remote command execution. DistCC is a distributed compilation service that, when improperly configured, allows attackers to send crafted requests to execute arbitrary system commands.

If accessible from the network, an attacker can execute commands with the privileges of the distccd service account, potentially leading to system compromise.

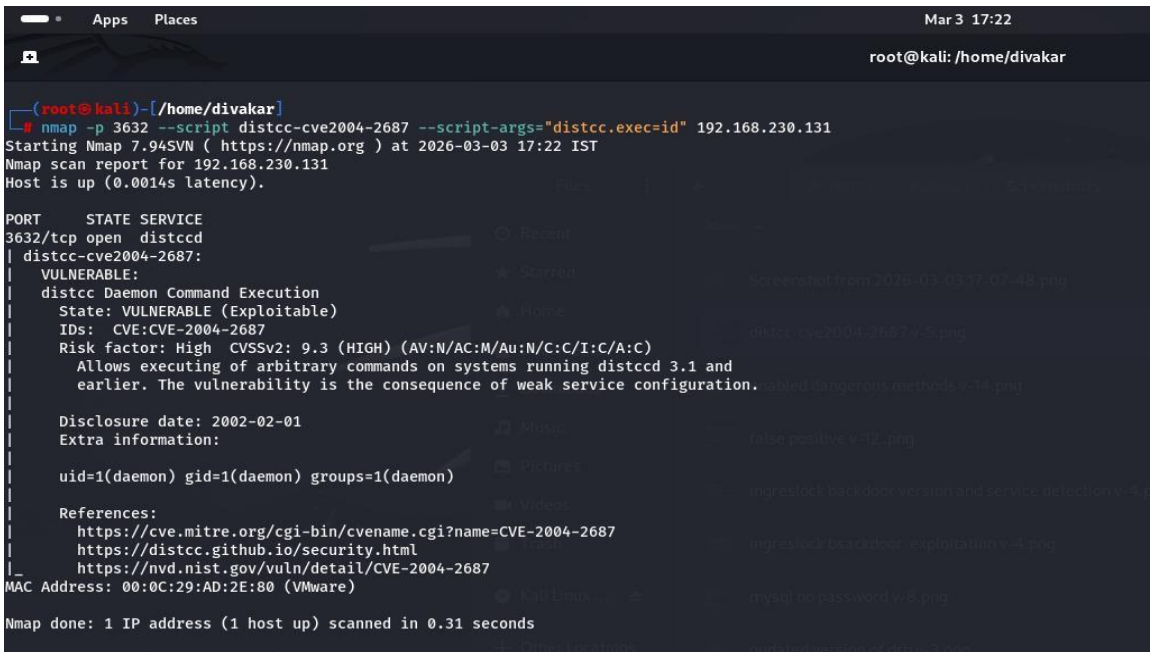
Proof of Concept (PoC)

Exploitation using Nmap NSE script:

nmap -p 3632 --script distcc-cve2004-2687 --script-args="distcc.exec=id" 192.168.230.131

Example output:

uid=1(daemon) gid=1(daemon)



The response confirms successful remote command execution.

Impact

An attacker can:

- Execute arbitrary system commands
- Gain remote shell access
- Escalate privileges (depending on system configuration)
- Install backdoors or malware
- Fully compromise the system

This vulnerability represents a serious risk due to unauthenticated remote execution capability.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Disable DistCC service if not required
- Restrict access to trusted internal hosts only
- Block port 3632 via firewall
- Upgrade or patch DistCC

V-06: VNC Brute Force Login

Severity: High (CVSS 9.0)

OID: 1.3.6.1.4.1.25623.1.0.106056

Port: 5900/tcp

Service: VNC (Virtual Network Computing)

Description

The VNC service running on port 5900 allows authentication using weak credentials. Automated testing indicated that the VNC server is susceptible to brute-force login attempts.

VNC authentication is password-based and, if weak passwords are used or no rate-limiting is enforced, attackers can gain unauthorized remote desktop access.

Proof of Concept(PoC)

Service detection:

nmap -p 5900 -sV 192.168.230.131

Brute-force validation (if confirmed):

vncviewer 192.168.230.131

Successful authentication confirms vulnerability.

Impact

An attacker can:

- Gain full remote desktop access
- Capture sensitive information
- Install malware
- Escalate privileges
- Fully compromise the system

Since VNC provides graphical system access, the impact is severe.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Set strong VNC passwords
- Disable VNC if not required
- Restrict access via firewall
- Implement network segmentation
- Use encrypted VNC tunnels (SSH)

V-07: MySQL / MariaDB Weak Password

Severity: High (CVSS 9.0)

OID: 1.3.6.1.4.1.25623.1.0.103551

Port: 3306/tcp

Service: MySQL

Description

The MySQL service allows authentication using weak or empty credentials. During testing, login as the root user was possible without a strong password.

Weak database credentials significantly reduce security controls and allow unauthorized users to access and manipulate sensitive data stored in the database.

Proof of Concept (PoC)

Service detection:

nmap -p 3306 -sV 192.168.230.131

Manual login attempt:

mysql -h 192.168.230.131 -u root --skip-ssl

Authentication was successful.

This confirms unauthorized database access.

Impact

An attacker can:

- Read, modify, or delete database records
- Create new administrative users
- Extract sensitive information
- Potentially escalate privileges to the operating system

Compromise of the database may result in full application compromise.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Change default and weak passwords immediately
- Disable remote root login
- Restrict database access to trusted hosts
- Implement strong password policies

V-08: PostgreSQL Weak Password

Severity: High (CVSS 9.0)

OID: 1.3.6.1.4.1.25623.1.0.103552

Detected Version: PostgreSQL 8.3.1

Port: 5432/tcp

Service: PostgreSQL

Description

The PostgreSQL service running on port 5432 allows authentication using weak default credentials. During testing, successful login was achieved using the username postgres and password postgres.

The postgres account has administrative privileges, providing full control over the database server.

Proof of Concept (PoC)

Product detection:

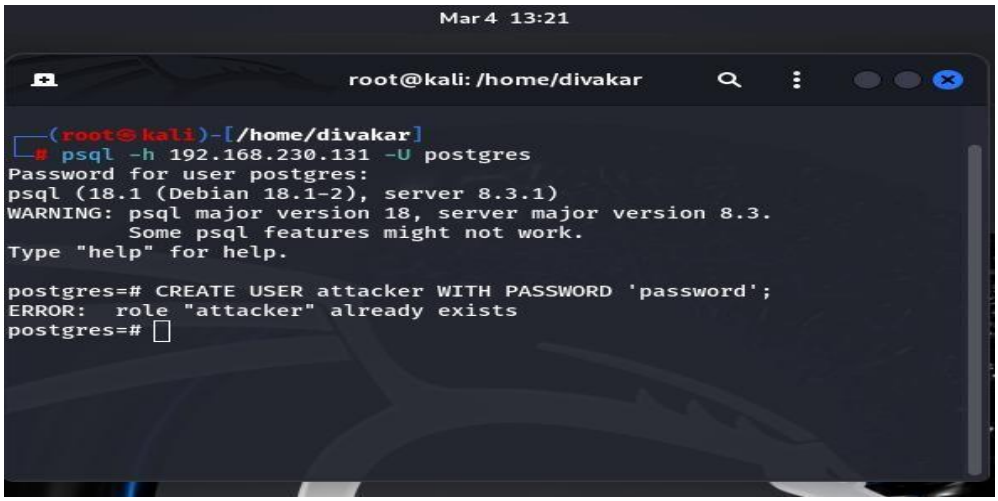
cpe:/a:postgresql:postgresql:8.3.1

Manual login attempt:

psql -h 192.168.230.131 -U postgres

Password used:

Postgres



Authentication was successful.

This confirms administrative access to the database.

Impact

- Unauthorized access to sensitive database records
- Data modification or deletion
- Creation of additional privileged users
- Potential privilege escalation

Compromise of the database may lead to complete application compromise.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
User Interaction	None
Confidentiality	Impact High
Integrity	Impact High
Availability Impact	High

Remediation

- Change default PostgreSQL credentials immediately
- Disable remote database access if not required
- Restrict access using firewall rules

- Enforce strong password policies
- Upgrade outdated PostgreSQL version

V-09: rsh Unencrypted Cleartext Login

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.100080

Port: 514/tcp

Service: rsh

Description

The rsh service is enabled on the target system and transmits authentication credentials and session data in cleartext. This means usernames, passwords, and executed commands can be intercepted by attackers monitoring network traffic.

The rsh protocol is outdated and insecure, lacking encryption and modern authentication protections.

Proof of Concept (PoC)

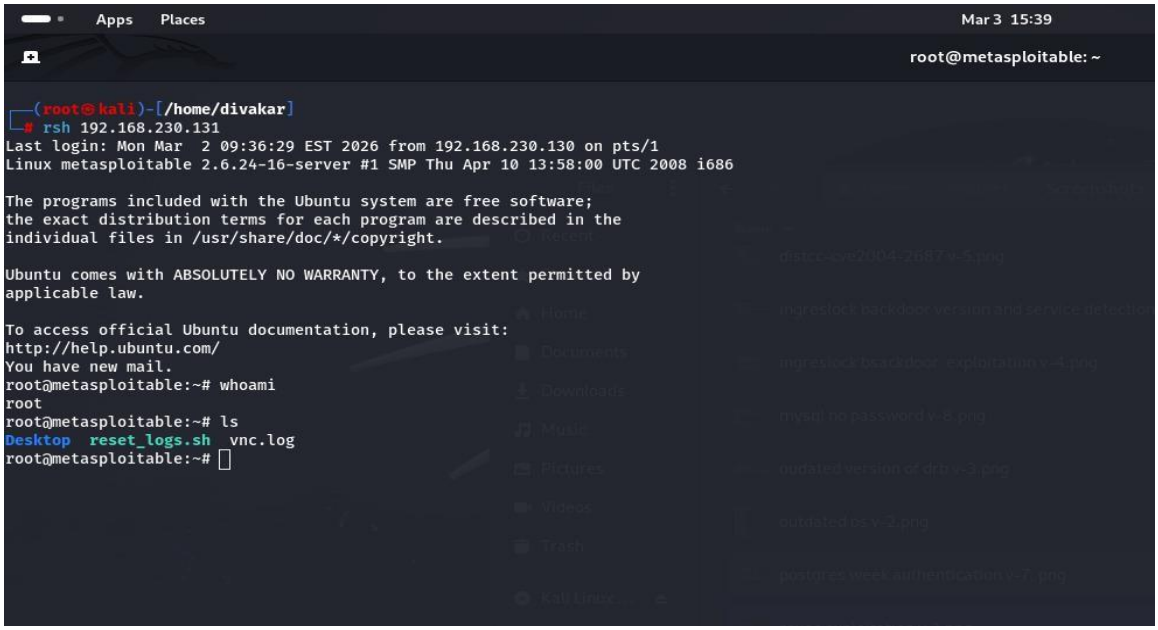
Service detection:

nmap -p 514 -sV 192.168.230.131

The service was confirmed to be accessible remotely.

Manual login attempt:

rsh 192.168.230.131



The service is misconfigured so it is allowing conntections without a password

---

Impact

An attacker can:

- Intercept usernames and passwords via network sniffing
- Capture executed commands
- Gain unauthorized remote access
- Compromise system confidentiality

Cleartext transmission significantly increases the risk of credential theft.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	Low
Availability	None

Remediation

- Disable rsh service immediately
- Remove legacy r-services packages
- Replace with secure alternatives such as SSH
- Restrict unnecessary network services

V-10: rlogin Passwordless / Unencrypted Cleartext Login

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.901202

Port: 513/tcp

Service: rlogin

Description

The rlogin service is enabled and allows remote login over an unencrypted channel. Authentication credentials and session data are transmitted in cleartext, making them susceptible to interception.

In some configurations, rlogin may also allow passwordless authentication through trusted host mechanisms (.rhosts), increasing the risk of unauthorized access.

Proof of Concept (PoC)

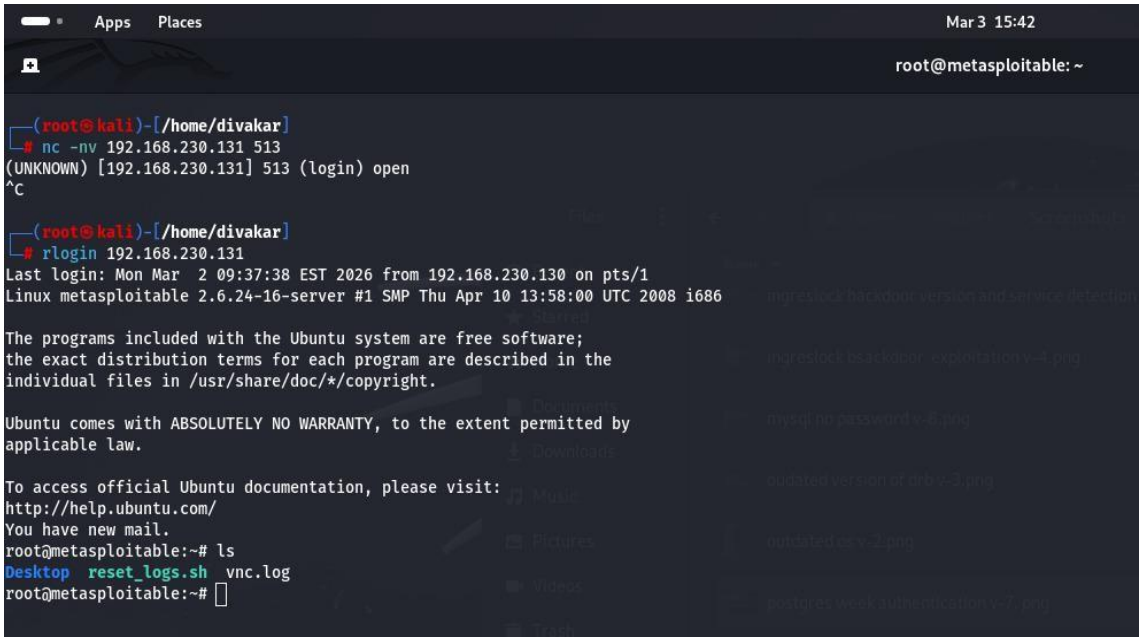
Service detection:

nmap -p 513 -sV 192.168.230.131

The rlogin service was found to be accessible remotely.

Manual login attempt:

rlogin 192.168.230.131



The service is misconfigured so it is allowing conntections without a password.

Impact

An attacker can:

- Intercept login credentials via network sniffing
- Gain unauthorized remote access
- Execute commands on the target system
- Compromise system confidentiality

The lack of encryption significantly increases exposure risk.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	Low
Availability	None

Remediation

- Disable rlogin service immediately
- Remove legacy r-services packages
- Replace with secure alternatives such as SSH
- Restrict unnecessary network services

V-11: phpinfo() Output Information Disclosure

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.11229

Port: 80/tcp

Service: HTTP / PHP

Description

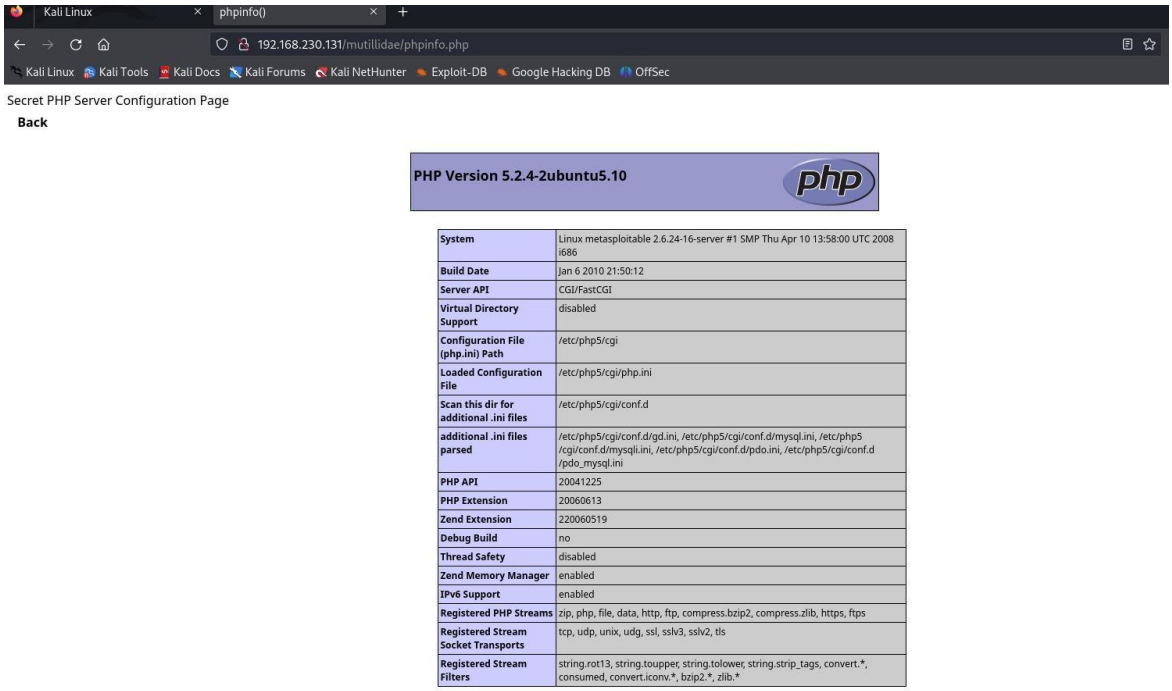
A publicly accessible phpinfo() page was identified on the web server. The phpinfo() function reveals detailed configuration information about the PHP environment, including PHP version, server paths, enabled extensions, and environment variables.

This information can be leveraged by attackers to perform targeted attacks and identify additional vulnerabilities.

Proof of Concept (PoC)

The phpinfo() page was accessed directly via the web browser:

http://192.168.230.131/phpinfo.php



System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

The page returned detailed PHP configuration information.

Impact

An attacker can:

- Obtain detailed server and PHP configuration information
- Identify installed modules and versions
- Discover file system paths and environment variables
- Use the information to plan further attacks

While this issue does not directly allow code execution, it significantly aids reconnaissance.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	Low
Availability	None

Remediation

- Remove phpinfo() pages from production systems
- Restrict access to diagnostic scripts
- Apply secure coding practices
- Review exposed web resources

V-12: Tiki Wiki CMS Groupware < 4.2 Multiple Unspecified Vulnerabilities

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.100537

Port: 80/tcp

Service: HTTP

Description

The automated scanner reported the presence of Tiki Wiki CMS Groupware version < 4.2, which is associated with multiple unspecified vulnerabilities.

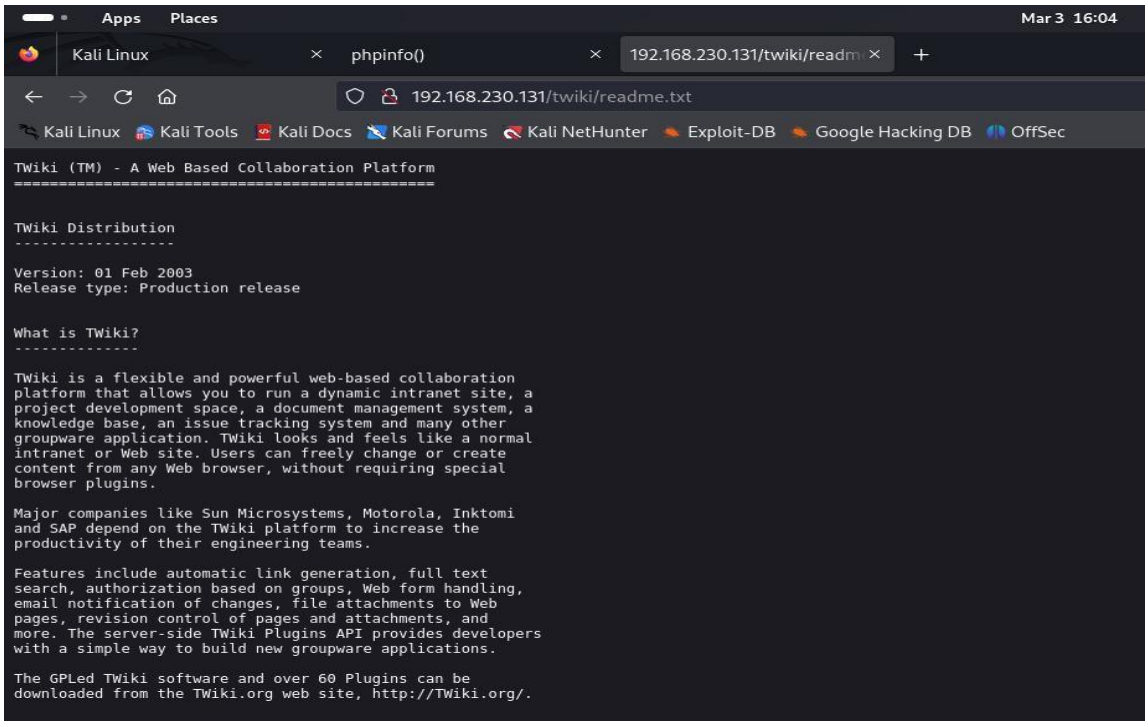
However, manual validation confirmed that the application hosted on the server is **TWiki**, not Tiki Wiki CMS Groupware. The detection occurred due to naming similarity between the two applications.

Proof of Concept (PoC)

Manual inspection of the web application:

http://192.168.230.131/twiki/

Application content confirmed it is TWiki and not Tiki Wiki CMS.



No evidence of Tiki Wiki CMS installation was found.

Impact

No impact observed, as the reported vulnerable software is not present on the system.

Risk Justification

Metric	Value
Attack Vector	Not Applicable
Attack Complexity	Not Applicable
Privileges Required	Not Applicable
User Interaction	Not Applicable
Confidentiality	None
Integrity	None
Availability	None

Remediation

- No action required
- Ensure accurate application fingerprinting during future scans

V-13: Check for Backdoor in UnrealIRCd

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.80111

Port: 6667/tcp

Service: UnrealIRCd

Description

The automated scanner reported a potential backdoor vulnerability in the UnrealIRCd service running on the target system. Certain versions of UnrealIRCd were historically distributed with a malicious backdoor that allows attackers to execute arbitrary system commands remotely.

Manual validation was performed to verify the presence of the backdoor functionality.

Proof of Concept (PoC)

Service detection:

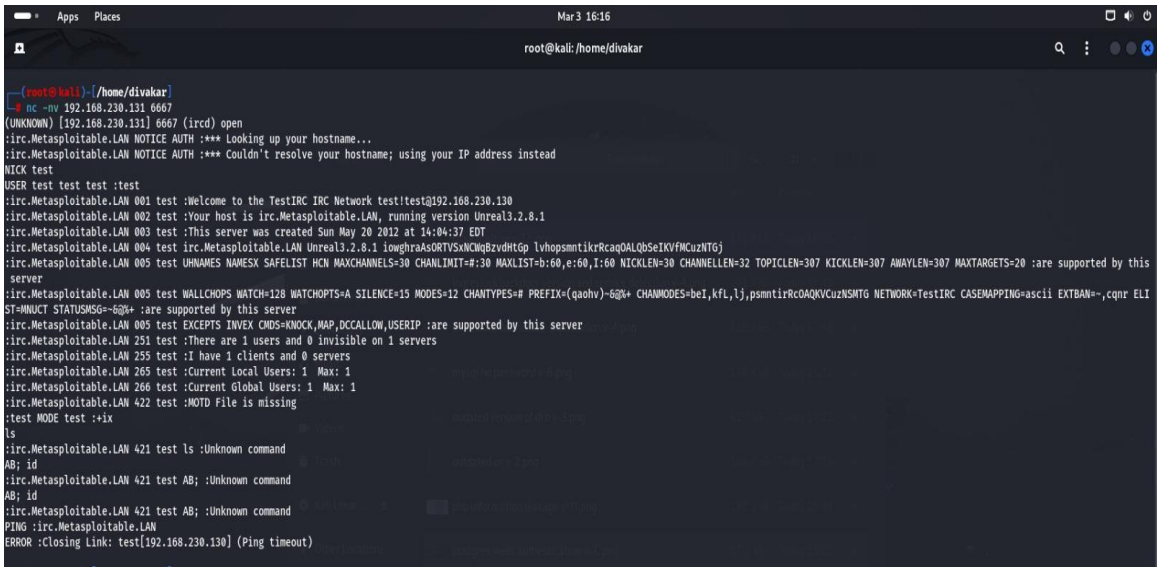
nmap -p 6667 -sV 192.168.230.131

Manual connection to IRC server:

nc 192.168.230.131 6667

Backdoor test command:

AB; id



The server returned **Unknown command**, indicating that the backdoor command execution was not possible.

Impact

No impact observed as the backdoor functionality could not be reproduced during manual testing.

Risk Justification

Metric	Value
Attack Vector	Not Applicable
Attack Complexity	Not Applicable
Privileges Required	Not Applicable
User Interaction	Not Applicable
Confidentiality	None
Integrity	None
Availability	None

Remediation

- No immediate action required
- Maintain regular software updates
- Monitor services for suspicious activity

V-14: HTTP Dangerous Methods Enabled

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.10498

Port: 80/tcp

Service: HTTP (Apache)

Description

The web server allows dangerous HTTP methods such as **PUT and DELETE**. These methods allow remote users to upload or remove files on the web server if not properly restricted.

Allowing these methods without proper authentication can enable attackers to upload malicious files or remove important resources from the server.

Proof of Concept (PoC)

Check allowed HTTP methods:

curl -X OPTIONS http://192.168.230.131 -i

Create a test file on the server:

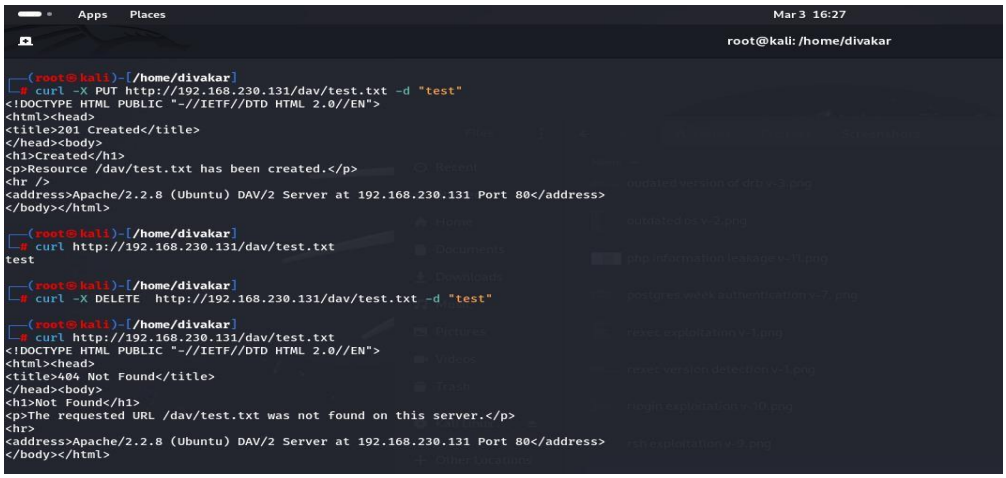
curl -X PUT http://192.168.230.131/test.txt -d "test"

Verify the uploaded file:

curl http://192.168.230.131/test.txt

Delete the uploaded file:

curl -X DELETE http://192.168.230.131/test.txt



The file was successfully created and deleted, confirming that dangerous HTTP methods are enabled.

Impact

An attacker can:

- Upload malicious files or web shells
- Delete important web application files
- Modify web server content
- Potentially gain remote code execution

This increases the risk of web server compromise.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	Low
Integrity	High
Availability	Low

Remediation

- Disable unnecessary HTTP methods (PUT, DELETE)
- Restrict allowed methods to **GET and POST**
- Configure Apache security settings properly
- Implement proper authentication and access controls

V-15: vsftpd Compromised Source Packages Backdoor Vulnerability

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.103185

Port: 6200/tcp (Backdoor Shell)

Service: vsftpd

Description

The scanner reported that the system may be running a version of **vsftpd** associated with a compromised source package that contains a malicious backdoor. When triggered through a specially crafted FTP login request, the backdoor opens a remote shell on **TCP port 6200**.

Manual verification was performed to determine whether the backdoor shell was active on the target system.

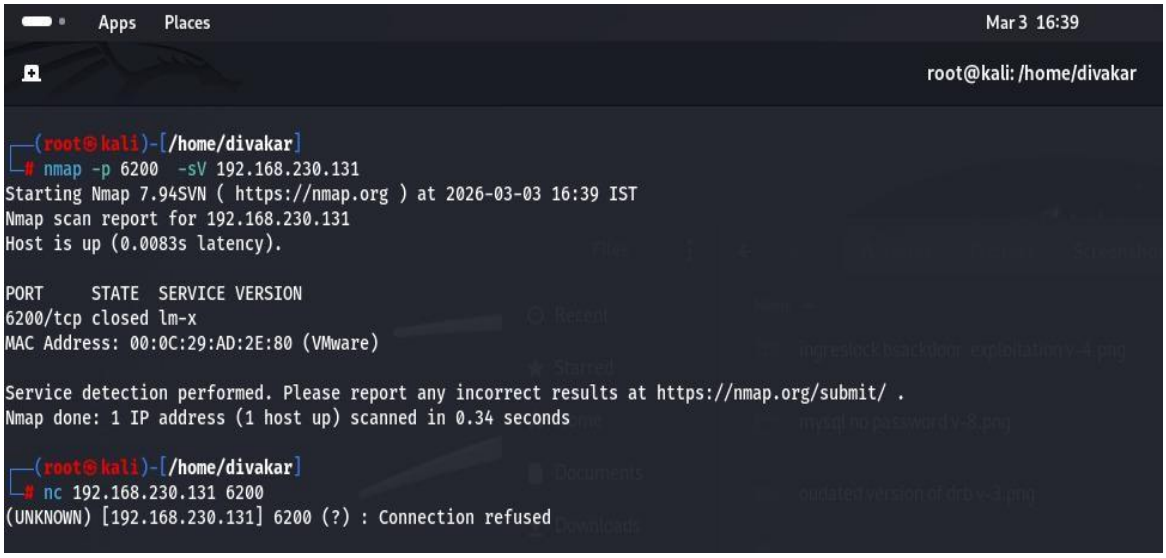
Proof of Concept (PoC)

Attempt to access the backdoor shell:

nc 192.168.230.131 6200

Result:

Connection refused



The backdoor port was not accessible during testing, indicating that the vulnerability could not be reproduced.

Impact

No impact observed during testing since the backdoor shell could not be accessed.

Risk Justification

Metric	Value
Attack Vector	Not Applicable
Attack Complexity	Not Applicable
Privileges Required	Not Applicable
User Interaction	Not Applicable
Confidentiality	None
Integrity	None
Availability	None

Remediation

- Ensure FTP services are updated to secure versions
- Regularly monitor FTP services for suspicious behavior
- Apply security patches and updates

V-16: FTP Weak / Default Credentials Allowed

Severity: High (CVSS 7.5)

OID: N/A

Port: 21/tcp

Service: FTP (vsftpd)

Description

The FTP service allows authentication using default credentials through **anonymous login**. During testing, the server accepted login attempts using the username **anonymous** without requiring valid user authentication.

Allowing anonymous or default credentials exposes the FTP service to unauthorized access and may allow attackers to retrieve sensitive files stored on the server.

Proof of Concept (PoC)

Service detection:

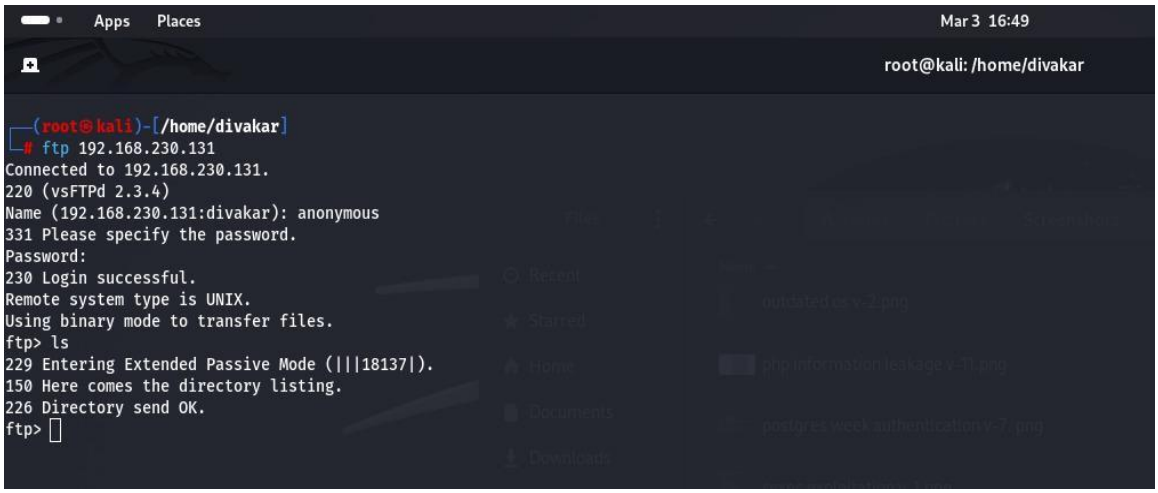
nmap -p 21 -sV 192.168.230.131

Manual login attempt:

ftp 192.168.230.131

Credentials used:

Username: anonymous
Password: anonymous



Authentication was successful, confirming unauthorized FTP access.

Impact

An attacker can:

- Access files stored on the FTP server
- Download sensitive information
- Upload malicious files if write permissions are enabled
- Use the FTP service as an entry point for further attacks

Unauthorized FTP access may result in data exposure and system compromise.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	Low
Availability	Low

Remediation

- Disable anonymous FTP login if not required
- Enforce strong authentication for FTP users
- Restrict FTP access to trusted users and networks
- Monitor FTP logs for suspicious activity

V-17: PHP-CGI-based Setups Vulnerability when Parsing Query String Parameters

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.103482

Port: 80/tcp

Service: HTTP / PHP-CGI

Description

The automated vulnerability scanner reported a potential vulnerability in **PHP-CGI setups when parsing query string parameters**. This issue may allow attackers to inject PHP configuration directives through crafted URLs, which could potentially lead to remote code execution.

Manual validation was performed to confirm the presence of this vulnerability on the target system.

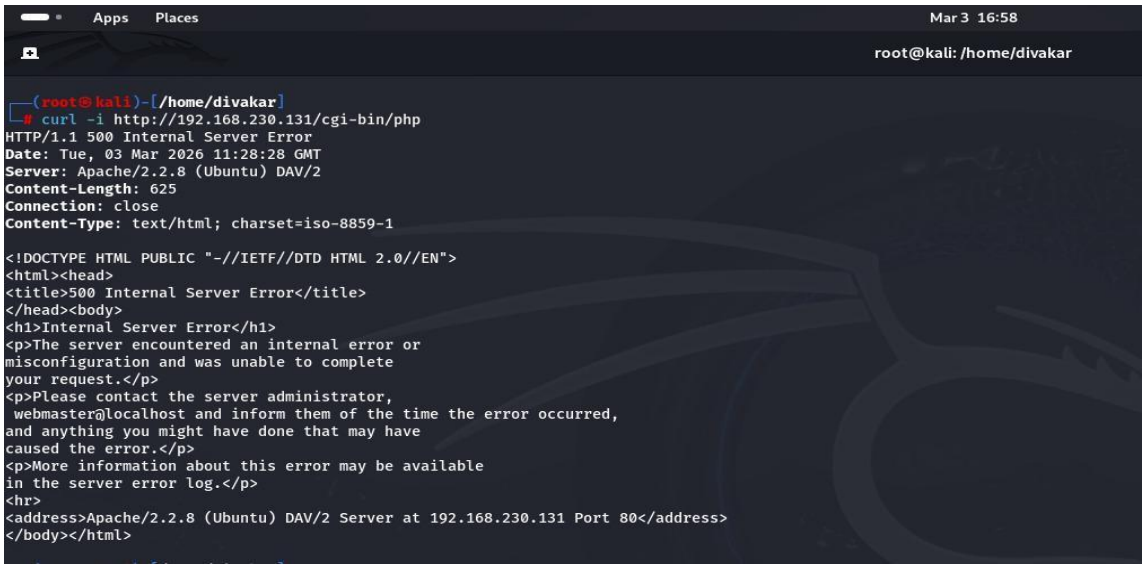
Proof of Concept (PoC)

The vulnerable URL identified by the scanner:

http://192.168.230.131/cgi-bin/php

Manual verification:

curl -i http://192.168.230.131/cgi-bin/php



The server returned **HTTP 500 Internal Server Error**, and no PHP configuration disclosure or code execution was observed.

Impact

No impact observed during testing since the vulnerability could not be reproduced.

Risk Justification

Metric	Value
Attack Vector	Not Applicable
Attack Complexity	Not Applicable
Privileges Required	Not Applicable
User Interaction	Not Applicable
Confidentiality	None
Integrity	None
Availability	None

Remediation

- No immediate action required
- Ensure PHP components are regularly updated
- Periodically review web server configurations for security

V-18: SSH Brute Force Logins With Default Credentials

Severity: High (CVSS 7.5)

OID: 1.3.6.1.4.1.25623.1.0.103239

Port: 22/tcp

Service: SSH

Description

The SSH service running on port 22 allows authentication using **default credentials**. During testing, successful login was achieved using the credentials **msfadmin:msfadmin**.

Default credentials significantly weaken authentication controls and allow unauthorized users to gain remote shell access to the system.

Proof of Concept (PoC)

Service detection:

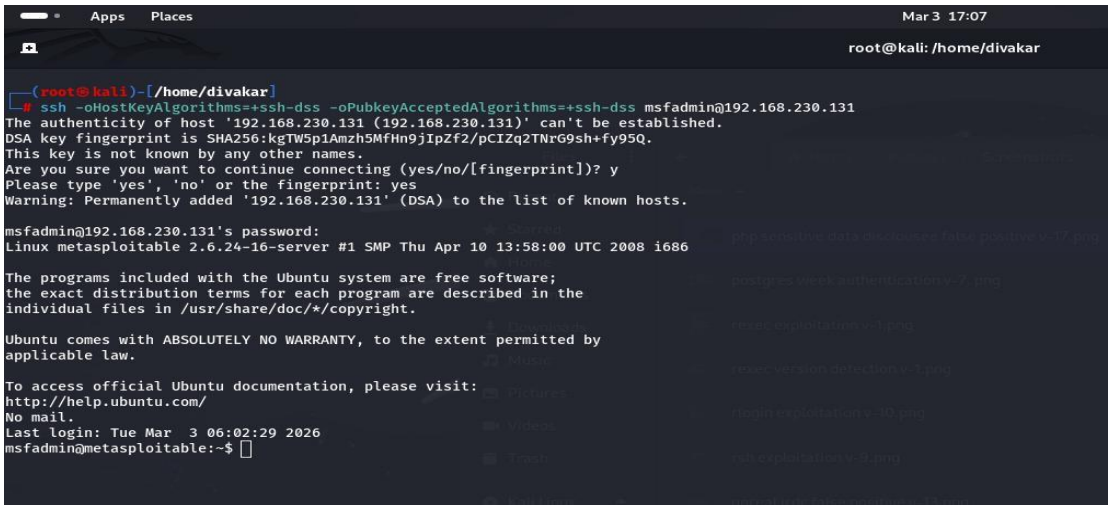
nmap -p 22 -sV 192.168.230.131

Manual login attempt:

ssh -oHostKeyAlgorithms=+ssh-dss -oPubkeyAcceptedAlgorithms=+ssh-dss msfadmin@192.168.230.131

Credentials used:

Username: msfadmin
Password: msfadmin



Authentication was successful and remote shell access was obtained.

Impact

An attacker can:

- Gain unauthorized remote shell access
- Execute arbitrary system commands
- Escalate privileges or maintain persistence
- Use the compromised system to launch further attacks

Successful SSH access may lead to **full system compromise**.

Risk Justification

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Confidentiality	High
Integrity	High
Availability	High

Remediation

- Remove default credentials immediately
- Enforce strong password policies
- Disable password authentication and use SSH key-based authentication
- Implement account lockout mechanisms to prevent brute-force attacks
- Monitor SSH logs for suspicious login attempts